# Information about the exam

Welcome to the exam for Secure Computer Systems I! This year's exam is a multiple choice exam with 23 graded questions, graded as pass or fail. **The maximum score is 36 points. To pass, you need at least 24 points.**

The 23 exam questions are divided into sections, roughly corresponding to the lecture topics. For each question where you can choose multiple alternatives, to discourage from simply choosing all alternatives, **incorrect alternatives will be penalized** with -1 points. However, to encourage you to answer every question, negative points don't carry over to other questions: **each question gives in the worst case 0 marks**.

*Example:*
*If there are 2 correct answers (one point each) and 3 incorrect answers (minus one point each) and you choose all 5 answers, the question will result in points marks (not minus one!).*

**In other words, the exam is designed to encourage answering, but to discourage from simply guessing.**

I strive to grade the exam fairly—at the end of the exam, you can write comments in a dedicated (ungraded) question to let me know if there is a problem/ambiguity in the exam questions, and justify why your answers are correct.

Good luck!

# 1 Confidentiality

The goal of the property *confidentiality* is:

**Select all correct alternatives:**

- [ ] To add redundancy to something
- [ ] To hash something
- [ ] To encrypt something
- [ ] To keep something secret
- [ ] To make sure something can be accessed
- [ ] To verify someone's identity
- [ ] To protect something from being modified

---

Maximum marks: 1

## 2 Integrity

The goal of the property *integrity* is:

**Select all correct alternatives:**

- [ ] To hash something
- [ ] To protect something from being modified
- [ ] To make sure something can be accessed
- [ ] To add redundancy to something
- [ ] To encrypt something
- [ ] To verify someone's identity
- [ ] To keep something secret

---

Maximum marks: 1

# 3 Availability

The goal of the property *availability* is:

**Select all correct alternatives:**

- [ ] To keep something secret
- [ ] To verify someone's identity
- [ ] To add redundancy to something
- [ ] To hash something
- [ ] To encrypt something
- [ ] To protect something from being modified
- [ ] To make sure something can be accessed

---

Maximum marks: 1

# 4 Threat models

What is the purpose of a *threat model*?

**Select all correct alternatives:**

- [ ] To define what the attacker can do
- [ ] To model the complexity of the system
- [ ] To model exploits an attacker can use
- [ ] To track system activity
- [ ] To provide definitions used to prove correctness of the system
- [ ] To identify the vulnerabilities of a system

---

Maximum marks: 2

# 5 Design principles

Saltzer and Schroeder's design principles from 1975 are still relevant guidelines for designing secure systems. The principles are:

- Economy of mechanism
- Fail-safe defaults
- Complete mediation
- Open design
- Separation of privilege
- Least privilege
- Least common mechanism
- Psychological acceptability

**Which of the following statements about the design principles are true?**

**Select all correct alternatives:**

- [ ] Complete mediation: access control decisions should be made primarily when a user enters a system.
- [ ] Open design: widely accepted design patterns should be employed when implementing security mechanisms.
- [ ] Fail-safe defaults: default settings should be restrictive.
- [ ] Psychological acceptability: security features should be as transparent as possible, allowing the user to decide if they want to use them or not.
- [ ] Least common mechanism: all users should share the same mechanisms and resources.
- [ ] Separation of privilege: multiple independent conditions or privileges should be required to access critical resources.

---

Maximum marks: 2

# 6 Asymmetric and symmetric encryption

A group of 12 users want to establish secure channels among themselves. This means, every two users should be able to communicate in a way that is indecipherable by the other users. For this purpose, they are deciding between using either symmetric or public-key (asymmetric) cryptography. Which of the following statements are true?

**Select all correct alternatives:**

- [ ] A user would have to remember more secret keys if public-key cryptography was used
- [ ] Symmetric encryption algorithms are generally faster
- [ ] Symmetric cryptography requires fewer keys in total
- [ ] Adding a new user to the group is easier for public-key cryptography (i.e., it entails generating fewer keys)
- [ ] Leakage of a secret key would compromise more secure channels if public-key cryptography is used

---

Maximum marks: 2

## 7 Signatures

Signatures uses public/private key pairs. When Alice wants to use such public/private key pairs when communicating with Bob, which statements are true?

**Select all correct alternatives:**

- [ ] Decrypting a message from Bob requires Bob's private key
- [ ] Encrypting a message from Alice to Bob requires Bob's private key
- [ ] Encrypting a message from Alice to Bob requires Bob's public key
- [ ] Verifying a signature from Bob requires Bob's public key
- [ ] Verifying a signature from Bob requires Bob's private key
- [ ] Sending a signed message from Alice to Bob requires Bob's private key
- [ ] Sending a signed message from Alice to Bob requires Alice's private key

---

Maximum marks: 3

## 8 Replay attacks

What are important defense techniques or properties against a *replay attack*?

**Select all correct alternatives:**

- [ ] Challenge-response protocols
- [ ] Authentication
- [ ] Hashing
- [ ] Freshness
- [ ] Integrity

---

Maximum marks: 2

## 9 Salting

What is the purpose of *salting* a password?

**Select all correct alternatives:**

- [ ] To make it more difficult for an attacker to target individual users
- [ ] To make the password longer
- [ ] To increase the likelihood of the password being unique
- [ ] To allow the password to be stored as plaintext

---

Maximum marks: 1

## 10 Capability lists vs access control lists

An *access control matrix* can be implemented using c*apability lists* (CL) or a*ccess control lists* (ACL). CLs are per-subject lists of <object, set of rights>, and ACLs are per-object lists of <subject, set of rights>. **Which is better, when?**

**Select all correct alternatives:**

- [ ] ACLs are better when the owner of an object often needs to revoke access rights to it
- [ ] ACLs are better when subjects often need to have all their rights revoked
- [ ] ACLs often allow delegation of rights between subjects
- [ ] CLs are better to quickly see who has access to each object
- [ ] CLs give a better overview of which subjects have access to a particular object

---

Maximum marks: 1

# 11 Access control models

*Mandatory access control* (MAC) and d*iscretionary access control* (DAC) are two different access control models. Which of the following statements are **not** true?

**Select all false alternatives:**

- [ ] In MAC, the owner decides who has access to their object
- [ ] In MAC, access rights are defined centrally
- [ ] In DAC, the owner decides who has access to their object
- [ ] In DAC, access rights are defined centrally

---

Maximum marks: 2

# 12 Vulnerable C code

The C program (Listing 1) executes a *sensitive* function only if the user provides the correct 4-digit number. The constant *PIN* stores the correct PIN, but its contents are unknown, other than the fact that it is a 5-byte string in which a 4-digit number is stored. The binary is compiled for a 32-bit architecture.

**Which line introduces a buffer overflow vulnerability in the given program?**

```
1  #define PIN "..." // 5-byte string storing 4-digit number
2  void sensitive () {
3   // . . .
4  }
5  int main() {
6   char secret[] = PIN;
7   char input[5]; // make room for end of string char '\0'
8   printf("Input 4-digit PIN: \n");
9   gets(input);
10  if (strcmp(input, secret) == 0) {
11   printf("Authenticated successfully\n");
12   sensitive();
13   return 1;
14  } else {
15   printf("PIN is incorrect\n");
16   return 0;
17   }
18 }
```

Listing 1: Vulnerable progam

**Select one alternative**

- Line 2
- Line 6
- Line 7
- Line 8
- Line 9
- Line 10
- Line 11
- Line 15

Maximum marks: 3

## 13 Injection attacks

*Injection attacks* are common software attacks, for example SQL injections. Which of the following are effective defenses against injection attacks?

**Select all correct alternatives:**

- [ ] Using strong passwords
- [ ] Input sanitization on the client-side
- [ ] Treating input as code
- [ ] Turning off error messages
- [ ] Input sanitization on the server-side
- [ ] Treating input as data

Maximum marks: 2

## 14 AppArmor design principle

*AppArmor* ("Application Armor") is a Linux kernel security module that allows the system administrator to restrict programs' capabilities with per-program profiles. Which of the following *design principles* (Saltzer and Schroeder) does AppArmor primarily address?

**Select the most relevant design principle:**

- ( ) Economy of mechanism
- ( ) Open design
- ( ) Complete mediation
- ( ) Least common mechanism

Maximum marks: 1

## 15 Malware type

What is a malware that replicates itself but typically does not alter its behavior called?

**Select all correct alternatives:**

- [ ] Trojan
- [ ] Ransomware
- [ ] Virus
- [ ] Worm

---

Maximum marks: 1

## 16 Zero-day

What is a *zero-day* vulnerability?

**Select all correct alternatives:**

- [ ] A vulnerability that is unknown to the vendor
- [ ] A vulnerability that gets exploited fast
- [ ] A vulnerability that is known to the vendor
- [ ] A vulnerability that has been patched

---

Maximum marks: 1

## 17 Sandboxing

Sandboxing is a defensive mechanism to improve security. Which of the following is the design principle (by Saltzer and Schroeder) that *best* addresses sandboxing?

**Select the most fitting alternative:**

- Least common mechanism
- Economy of mechanism
- Open design
- Fail-safe defaults

---

Maximum marks: 1

## 18 Distributed denial-of-service (DDoS) attacks

Protecting against *distributed denial-of-service* (DDoS) attacks based on address spoofing is difficult. What defensive mechanism most often provides effective protection?

**Select all correct alternatives:**

- [ ] Encrypting traffic
- [ ] Using DNSsec
- [ ] Upgrading your network interface to handle more incoming traffic
- [ ] Let endpoint routers filter packets with spoofed addresses when they enter or exit a local network

---

Maximum marks: 1

## 19 Malformed packets

Many network attacks include using *malformed* packets. What can cause malformed packets in IPv4?

**Select all correct alternatives:**

- [ ] Network congestion
- [ ] Outdated routing protocols
- [ ] Improper firewall configurations
- [ ] Intentional packet manipulation
- [ ] Weak encryption schemes

---

Maximum marks: 1

## 20 Anonymization

Privacy-preserving data analysis often involves *anonymization* to guarantee the confidentiality of inputs (data) when releasing some statistics. What are some common reasons for why anonymization is difficult and sometimes results in *re-identification*?

**Select all correct alternatives:**

- [ ] Anonymization only works on small data sets
- [ ] Anonymization algorithms are computationally expensive
- [ ] Lack of a proper threat model
- [ ] Anonymization only works on large data sets
- [ ] The existence of background data

---

Maximum marks: 2

## 21 Online privacy

Suppose you want to avoid being tracked when surfing the web. Which of the following are **not** effective ways to protect you from being tracked?

**Select all ineffective alternatives:**

- [ ] Running antivirus software
- [ ] Using a popular search engine
- [ ] Browsing in incognito mode
- [ ] Using a browser with default settings
- [ ] Disabling JavaScript
- [ ] Using the Tor browser
- [ ] Blocking social media buttons

---

Maximum marks: 3

## 22 Intentional flaws

What is the term for a security flaw that is *intentionally* left in the system?

**Select all correct alternatives:**

- [ ] Backdoor
- [ ] Weakness
- [ ] Exploit
- [ ] Vulnerability

---

Maximum marks: 1

## 23 Ethical hacking

Which of the following is *not* a principle of ethical hacking?

**Select all alternatives that are not part of ethical hacking:**

- [ ] Causing no harm to the system
- [ ] Obtaining permission in advance
- [ ] Disclosing the vulnerability publicly
- [ ] Abiding the law

---

Maximum marks: 1

## 24 Comments

Feedback/comments on the exam design.
**In case you think something is incorrect or ambiguous in the exam design, please fill in your comments here and we will take it into account when grading:**

---

Maximum marks: 0